Diseño de un pipeline seguro

Unidad 3.2 | Nombre o integrantes: Benjamín Ibáñez y Gerardo Vera

Sistema y cambio elegido

Sistema elegido: Cuidarte+ (caso B). Cambio: nuevo endpoint del backend para descargar en PDF los exámenes del propio paciente autenticado. Dato afectado: los exámenes son datos de salud, los más sensibles del sistema; si el endpoint falla o no valida quién pide qué, un paciente podría descargar los exámenes de otra persona (acceso indebido a información ajena).

Diagrama del pipeline

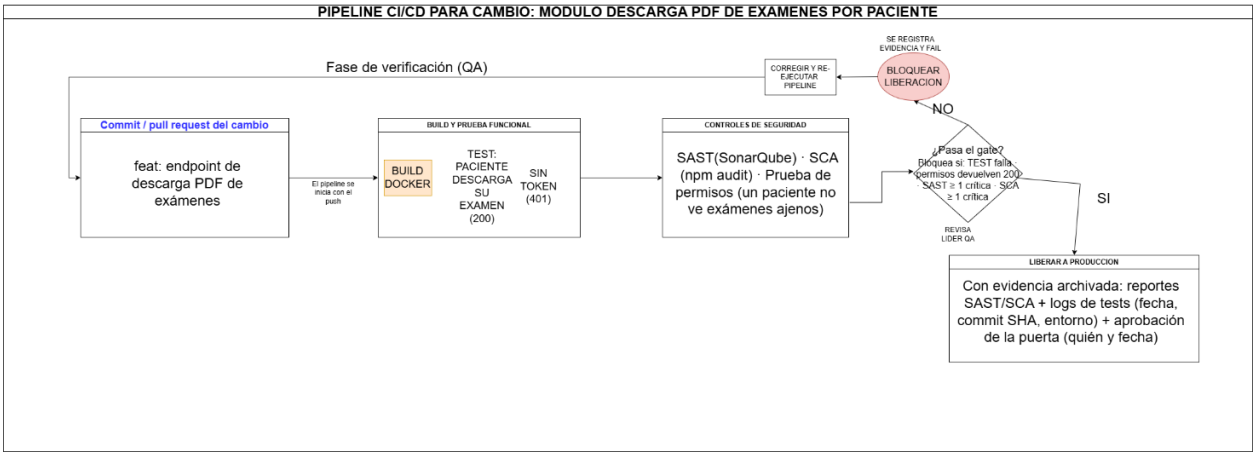


Figura 1 · Diagrama del pipeline: desde el commit hasta la decisión de liberar.

La secuencia es comprensible de principio a fin: (1) commit o pull request del cambio → (2) build y prueba funcional → (3) controles de seguridad → (4) puerta de calidad → (5) si pasa, liberar a producción con evidencia; si no, bloquear, corregir y re-ejecutar todo el pipeline.

Explicación de controles

Control	¿Qué revisa?	¿Qué riesgo ayuda a detectar?	¿Qué resultado entrega al equipo?
Prueba funcional (descarga de PDF)	Que el paciente autenticado descarga su propio examen (200 + PDF válido) y que sin token se rechaza (401).	Que el cambio no funciona o que el endpoint quedó abierto.	Informe de la prueba: 200 / 401, o el fallo con su detalle.
SAST — SonarQube	El código del cambio sin ejecutarlo (bugs y vulnerabilidades).	Código inseguro ya en el repositorio.	Reporte de incidencias clasificadas por severidad.
SCA — npm audit	Las dependencias del proyecto contra vulnerabilidades conocidas (CVE).	Una librería vulnerable llegando a producción.	Lista de CVE con la versión que las corrige.
Prueba de permisos	Que el paciente A no puede pedir el examen del paciente B.	Acceso indebido a datos de salud de otra persona.	Respuesta 403/404 (nunca 200) con captura como evidencia.

El cambio incluye una prueba funcional y tres controles de seguridad relacionados con el riesgo del sistema (control de acceso a datos de salud). Un paciente distinto al dueño no debe ver jamás el examen de otro.

Regla de decisión

- Se bloquea la liberación si: la descarga no devuelve 200 con un PDF válido; la petición sin token no devuelve 401; el paciente A puede descargar el examen del paciente B (cualquier respuesta distinta de 403/404); SAST reporta al menos una incidencia crítica; o SCA reporta al menos una vulnerabilidad crítica con versión corregida disponible.
- Quién revisa: el líder técnico o el responsable de calidad (QA). El autor del cambio no se auto-aprueba; otra persona revisa el resultado de la puerta.
- Qué evidencia se conserva: los reportes de SAST y SCA, el log de pruebas (fecha, commit SHA y entorno) y el registro de la decisión de la puerta. Si se bloquea, se conserva igual, marcado como FAIL.

Analicen dos resultados

A. La prueba funcional pasa, pero una prueba de permisos muestra que un usuario accede a información de otra persona. ¿Qué decisión tomarían? ¿Por qué?

Respuesta: no se libera. Que la descarga funcione no compensa que un paciente vea los exámenes de otro; los datos de salud son el bien más sensible del sistema y este fallo es exactamente el riesgo que la prueba de permisos existe para detectar. Se corrige el control de acceso en el servidor, se agrega una prueba de regresión que cubra este caso y se vuelve a ejecutar todo el pipeline antes de decidir.

B. El análisis de dependencias no se ejecutó por un error de configuración. ¿Qué se sabe y qué no se sabe? ¿Qué harían antes de decidir la liberación?

Respuesta: se sabe que la etapa no se ejecutó; no se sabe si las dependencias son seguras o tienen vulnerabilidades. Un resultado sin análisis no es un resultado limpio. Antes de liberar se corrige la configuración y se ejecuta el análisis sobre el mismo commit; si no es posible, se ejecuta npm audit manualmente sobre el mismo commit y lo aprueba por escrito el líder técnico. Si el análisis no logra hacerse, la puerta de calidad no pasa y no se libera.

Preguntas de cierre

¿Qué ventaja entrega automatizar controles? Que se ejecuten igual en cada cambio, sin depender de que alguien se acuerde, en minutos y dejando registro de la evidencia.

¿Por qué un resultado sin alertas no demuestra por sí solo que el sistema sea seguro? Porque cada control solo ve su parte; un resultado sin alertas solo dice que ese control no encontró nada en lo que revisó, no que el sistema no tenga riesgos.